# 壁垒WAF 使用手册

内蒙古勤加软件有限公司

2026 年 10 月 · 版本 v1.0.5

内蒙古勤加软件有限公司 · © 2026 版权所有

# 目 录

1 快速开始 3

2 登录管理后台 3

3 安全防护监控大屏 3

4 攻击日志 3

5 站点管理 4

6 证书管理 4

7 规则管理 4

8 端口与检测模式配置 5

9 AI 检测调优（可选） 5

10 CC 防护与人机验证 6

11 攻防演示页 6

12 日志与审计 6

13 日常运维速查 6

版本：v1.0.5 | 内蒙古勤加软件有限公司 | 2026 年 10 月

# 1 快速开始

安装并启动后，各功能入口如下（<IP> 为服务器地址，管理端口以 config/waf.conf 的 admin_port 为准，默认 19000）：

| 入口 | 地址 | 说明 |
| --- | --- | --- |
| 产品官网 | http://<IP>:19000/ | 产品介绍、防护能力矩阵、应用场景 |
| 攻防演示 | http://<IP>:19000/demo | 浏览器一键发起真实攻击并观察拦截 |
| 监控大屏 | http://<IP>:19000/screen.html | 全球攻击态势可视化（演示大屏） |
| 检测报告 | http://<IP>:19000/report.html | blazehttp 检测能力验证报告 |
| 管理后台 | http://<IP>:19000/admin/ | 站点 / 证书 / 规则 / 日志 / 端口管理 |

> 生产部署建议：数据平面 80/443 对外发布业务，管理端口 19000 限制在内网或通过防火墙白名单访问。

# 2 登录管理后台

1. 浏览器打开 http://<IP>:19000/admin/；
2. 输入账号密码（首次安装默认 admin / admin123）；
3. 登录后进入管理控制台。

安全机制：

- 密码以"随机盐 + SHA-256"存储在 config/admin.conf，明文不落盘；
- 连续登录失败将触发 429 限制，防止口令爆破；
- 会话鉴权，所有管理 API 均需有效会话；
- 首次登录后请立即修改密码（控制台右上角 → 修改密码）。

# 3 安全防护监控大屏

登录后首页即监控大屏，核心区域：

| 区域 | 内容 |
| --- | --- |
| 攻击统计卡 | 今日攻击数、本月拦截、本月攻击、本月请求、实时 QPS（后三项按自然月统计） |
| 全球攻击态势 | 攻击来源地理分布（需 GeoIP 支持） |
| 命中规则 TOP5 | 当前最活跃的攻击类型与规则 |
| 攻击趋势 | 攻击量随时间变化曲线 |
| 实时攻击流 | 滚动显示最新拦截事件（时间 / IP / 类型 / 规则） |

大屏数据由管理平面聚合攻击日志实时计算，可作为值守页全天投屏。

# 4 攻击日志

左侧菜单 → 攻击日志。

- 多维检索：按攻击类型、动作（拦截/放行）、来源 IP、关键词、时间窗组合过滤；
- 载荷留痕：每条记录展示完整攻击载荷与命中的规则名，可直接复制用于复现与规则调优；
- 日志底层文件为 logs/waf-attack.log，各站点另有独立 logs/<站点>/access.log。

## 5 站点管理

左侧菜单 → 站点管理。页面按域名列表展示：域名、后端、SSL 状态、启用状态；支持在线新增 / 更新 / 删除站点配置（生成 `config/sites/<域名>.conf`）。

新增站点关键字段：

| 字段 | 填写说明 |
| --- | --- |
| 域名 | 对外服务域名（Host 匹配），如 `app.example.com` |
| 后端地址 | 反向代理目标 `host:port`；纯静态站点可将端口设 0 并填写根目录 |
| HTTP/HTTPS 端口 | 该站点监听端口，默认 80 / 443 |
| SSL 证书 | 在"证书管理"签发或上传后绑定 |
| CC 人机验证 | 开启后 CC 超阈值先返回验证码（推荐业务站开启） |
| 缓存 / 限速 / gzip | 静态缓存大小与过期、请求限速阈值、压缩开关 |

保存后按提示重启数据平面（`sudo /opt/bileiwaf/waf restart`）生效。DNS 将域名解析到 WAF 服务器，业务流量即经 WAF 反代接入。

## 6 证书管理

左侧菜单 → 证书管理，支持三种方式：

1. Let's Encrypt 自动签发/续期（推荐）：选择站点域名一键签发（ACME 自动化）；到期前可一键续期，完成后自动热加载 SSL 上下文，无需重启；
2. 上传证书：上传 `fullchain.pem`（证书链）与 `privkey.pem`（私钥），绑定到站点；
3. 自签名证书：内网/测试环境一键生成（浏览器会提示不受信任）。

证书文件落盘于 `certs/` 目录，私钥权限 600。

## 7 规则管理

左侧菜单 → 规则文件。内置 1,087 条检测规则，按攻击类型分文件管理：

| 规则文件 | 条数 | 覆盖 |
| --- | --- | --- |
| `cmd_injection.rules` | 403 | 命令注入（OS Shell） |
| `sql_injection.rules` | 297 | SQL 注入 |
| `ssrf.rules` | 181 | 服务端请求伪造 |
| `xxe.rules` | 120 | XML 外部实体注入 |
| `xss.rules` | 41 | 跨站脚本 |
| `path_traversal.rules` | 20 | 路径穿越 |
| `scanner.rules` | 18 | 扫描器 / 探测指纹 |
| `file_upload.rules` | 7 | 恶意文件上传 |
| `whitelist.ip` / `whitelist.url` | - | IP / URL 白名单（跳过检测） |
| `blacklist.ip` | - | IP 黑名单（直接封禁；规则文件列表中显示红色「IP 黑名单」标签） |

规则运维：

- 白名单用于消除对已知正常业务的误报：将误报 URL 加入 `whitelist.url`、可信来源加入 `whitelist.ip`；

- 规则与黑白名单支持热加载：修改后 `sudo systemctl reload bileiwaf`（或 `kill -HUP $(cat /opt/bileiwaf/logs/bileiwaf.pid)`），无需中断业务；
- 开启 AILEARN（见第 9 节）后，AI 高分但规则未拦的载荷会自动聚类铸造新规则写入 `rules/ai_learned.rules`，铸造前经白名单全量评估防误报。

IP 自动黑名单（v1.0.5，动态拉黑）：`blacklist.ip` 的静态条目之外，系统还提供动态拉黑能力——同一 IP 在 CC 统计窗口内请求次数超过 CC 阈值（默认 60 次/60 秒，可经 `WAF_CC_MAX_REQUESTS` 等环境变量调整）时，除 CC 封禁外，该 IP 会同时被写入内存中的动态黑名单，期间全部请求直接 403，到期自动解封。特性要点：

- 动态条目只存内存，不修改 `blacklist.ip` 文件，重启后自动清空；
- 解封时长由 `config/waf.conf` 控制：`auto_blacklist_enabled = 1`（默认开）、`auto_blacklist_seconds = 600`（默认 600 秒）；
- 白名单 IP 优先豁免，不会被自动拉黑；管理后台手动解封时同步清除动态条目。

## 8 端口与检测模式配置

左侧菜单 → 端口配置，可在线修改并保存到 `config/waf.conf`（重启生效）：

| 配置项 | 取值 | 说明 |
| --- | --- | --- |
| HTTP / HTTPS 端口 | 任意未占用端口 | 数据平面监听 |
| 默认后端 | `host:port` | 未匹配站点的回退后端 |
| 管理端口 | 默认 19000 | 管理平面监听 |
| 检测模式 | `rules` / `ai` / `auto` | 见下表 |
| 工作模式 | `learning` / `detection` / `blocking` | 学习 / 检测告警 / 拦截 |

检测模式说明：

| 模式 | 行为 | 适用 |
| --- | --- | --- |
| `rules` | 仅规则引擎，确定性最高、零模型依赖 | 生产保守场景 |
| `ai` | 仅 AI 集成模型；模型缺失自动回退规则引擎兜底（fail-safe） | AI 灰度验证 |
| `auto` | AI 先判，AI 未拦截的再走规则引擎联级；检出率最高（实测 99.70%） | 生产推荐 |

## 9 AI 检测调优（可选）

在 `config/waf.conf` 中配置（`detection_mode = ai / auto` 时生效）：

| 键 | 说明 |
| --- | --- |
| `ai_ensemble_threshold` | AI 集成决策阈值 0~1，越高越保守（默认 0.5） |
| `ai_shadow_mode = on` | 影子模式：AI 只打分写 `logs/ai-shadow.log`，不参与拦截，用于上线前灰度验证 |
| `ai_guard_enabled = on` | 护栏自主学习（AILEARN）：AI<br>高分但规则未拦的载荷自动聚类铸造新规则，白名单全量评估通过才落盘 |
| `ai_white_list` | 铸造规则前用于误报评估的白名单样本集路径 |
| `ai_learned_rules` | 自学习规则产出文件（默认 `rules/ai_learned.rules`） |

推荐上线路径：`ai_shadow_mode=on` 观察 1~2 周影子日志 → 确认无误报后切换 `detection_mode=auto` → 视情况开启 `ai_guard_enabled`。

## 10 CC 防护与人机验证

- 默认策略：60 秒内同一 IP 超过 60 次请求触发处置（环境变量 `WAF_CC_MAX_REQUESTS` / `WAF_CC_TIME_WINDOW` / `WAF_CC_BLOCK_DURATION` 可覆盖）；
- 站点开启 `cc_captcha = 1` 时，超阈值访问者先收到 302 人机验证（图形验证码），验证通过后恢复访问；未开启则直接按封禁时长拒绝；
- 封禁期间该 IP 请求被拒绝，封禁时长默认 60 秒；
- 结合站点级 `request_limit`（rate/burst）可实现更细粒度的限速。

## 11 攻防演示页

访问 `http://<IP>:19000/demo`（无需登录）：

1. 攻击模拟器：点击任一攻击类型按钮（SQL 注入 / XSS / 命令注入 / 路径穿越 / XXE / SSRF 等），页面自动向 WAF 发起携带真实载荷的请求；
2. 实时结果：拦截返回 403（红色）、放行返回 200（绿色），统计卡实时更新拦截率；
3. 实时攻击日志：每 4 秒自动刷新，显示规则名、命中载荷、来源 IP；
4. 命令行验证：页面提供可复制的 `curl` 验证命令，便于在自己的终端复现。

常用验证命令示例：

```
# SQL 注入（应 403）
curl -sI "http://<IP>/?id=1%20UNION%20SELECT%20password%20FROM%20users"

# 路径穿越（应 403）
curl -sI --path-as-is "http://<IP>/../../etc/passwd"

# XSS（应 403）
curl -sI "http://<IP>/?q=<script>alert(1)</script>"

# 正常请求（应 200）
curl -sI "http://<IP>/"
```

## 12 日志与审计

| 文件 | 用途 |
| --- | --- |
| `logs/waf-attack.log` | 攻击拦截全量日志（后台"攻击日志"页的数据源） |
| `logs/waf-access.log` | 全局访问日志 |
| `logs/<站点>/access.log` | 站点访问日志（combined 格式） |
| `logs/waf-audit.log` | 管理操作审计（登录、配置变更） |
| `logs/ai-shadow.log` | AI 影子模式打分记录 |
| `logs/waf-crash.log` | 崩溃自诊断记录 |

日志轮转：站点日志按 `max_file_size`（MB）滚动，保留 `max_files` 份。

## 13 日常运维速查

```
cd /opt/bileiwaf
sudo ./waf status # 运行状态
sudo systemctl reload bileiwaf # 热加载规则 + 证书
sudo systemctl restart bileiwaf # 重启（配置改动后）
tail -f logs/waf-attack.log # 实时观察攻击拦截
cat logs/bileiwaf.pid # 数据平面 PID
```

内蒙古勤加软件有限公司 · © 2026 版权所有